Contents

1 Backup And Recovery Policy **1**
- 1.1 1. Policy Statement . . . 1
- 1.2 2. Covered Assets And Environments . . . 1
- 1.3 3. Recovery Objectives And Maximum Tolerable Disruption . . . 2
- 1.4 4. 3-2-1 Backup And Immutability Standard . . . 2
- 1.5 5. Backup Schedule And Automation . . . 2
- 1.6 6. Encryption, Access, Residency, And Monitoring . . . 2
- 1.7 7. Retention, Archive, And Secure Disposal . . . 3
- 1.8 8. Current Production Backup Control . . . 3
- 1.9 9. Automated Backup Operating Procedure . . . 3
- 1.10 10. Restoration Standard Operating Procedures . . . 4
  - 1.10.1 10.1 Common Recovery Controls . . . 4
  - 1.10.2 10.2 Single-File Or Object Recovery . . . 4
  - 1.10.3 10.3 Full Database Point-In-Time Recovery . . . 4
  - 1.10.4 10.4 Bare-Metal, System-Image, Or Complete Environment Recovery . . . 4
- 1.11 11. Testing, Reports, And Personnel Authorization . . . 5
- 1.12 12. Facility Hub Backup Policy . . . 5
- 1.13 13. Compliance, Exceptions, And Review . . . 5
- 1.14 14. Version And Approval Record . . . 5

1 Backup And Recovery Policy

System: Vitora HMIS **Policy owner:** Nexora Consulting Ltd Operations Lead **Effective date:** 15 October 2026 **Review frequency:** Annual and after a material infrastructure, supplier, security, or legal change **Baseline Recovery Time Objective:** 24 hours **Baseline Recovery Point Objective:** 24 hours

1.1 1. Policy Statement

Vitora HMIS production data must be backed up, protected from unauthorized access, verified for integrity, retained according to the applicable health-record retention requirement, and recoverable through a controlled restore procedure. Backups are resilience copies and must not be used as an uncontrolled secondary clinical system.

No production environment may rely on a manual backup as its primary protection. A control that is not implemented, tested, or evidenced must be recorded in the backup-control register as a risk and remediated before production use, unless the Security Lead, DPO, and designated facility representative approve a time-bound exception.

1.2 2. Covered Assets And Environments

This policy covers production, disaster-recovery, and facility-hub assets that process, store, transmit, or protect Vitora data.

Asset category	Covered assets
Application services	Next.js web application, Django API, background workers, container images, approved
Clinical and operational databases	Production PostgreSQL database, facility-hub SQLite database, synchronization state,
Cloud environments	Azure Container Apps, Azure Blob Storage, managed identities, Key Vault or approved
Virtual machines and physical servers	Any approved VM, facility-hub host, backup appliance, NAS, disk array, and physical r
Network configuration	DNS zones, firewall rules, private endpoints, VPN configuration, certificates, routing, al
Third-party hosted assets	Azure services, DNS/CDN providers, email/SMS gateways, payment, payer, laboratory

\newpage

1.3 3. Recovery Objectives And Maximum Tolerable Disruption

The targets below define the maximum acceptable outage or data loss after an incident. The **maximum tolerable period of disruption (MTPD)** is the maximum duration before unacceptable clinical, operational, legal, or financial harm is expected. Recovery must complete before the MTPD.

Tier	Data and services
Tier 1: critical clinical	Patient records, encounters, triage, orders, results, prescriptions, admissions, billing/claims
Tier 2: essential operational	Scheduling, facility-hub sync state, inventory/catalogue configuration, reporting work queu
Tier 3: supporting or reproducible	Versioned application artefacts, static reference data, non-clinical analytics extracts, and sy

The 24-hour Tier 1 baseline is the approved minimum recovery objective. Where a Tier 1 database supports point-in-time recovery, continuous transaction-log capture must reduce its operational RPO to 15 minutes or less. A facility must not represent the 15-minute target as achieved until the capture, retention, restore, and test evidence are approved.

1.4 4. 3-2-1 Backup And Immutability Standard

Critical data must follow the 3-2-1 rule:

1. Maintain at least three total copies: the production copy and at least two backup copies.
2. Store copies on at least two different media or storage types, such as managed database storage and encrypted object storage, or encrypted local disk/NAS and object storage.
3. Keep at least one backup copy in an isolated offsite environment that is logically air-gapped from production administration and cannot be modified or deleted by routine production credentials.

The offsite copy must use write-once-read-many (WORM), object-lock, immutable-vault, or equivalent retention-lock controls. Backup administrators may create and restore backup data but must not be able to shorten retention, delete protected copies, or alter immutable objects without separately controlled break-glass authorization and an audit record. Encryption, immutability, and restore testing must be verified before a backup location is accepted.

1.5 5. Backup Schedule And Automation

Backup activity	Covered tier	Requir
Full database snapshot	Tier 1 PostgreSQL and hub database	Daily a
Differential or incremental capture	Tier 1 and Tier 2 data where supported	At leas
Transaction-log / point-in-time capture	High-transaction Tier 1 PostgreSQL databases	Contin
Configuration and system-state export	Tier 2 and Tier 3 cloud, network, VM, and host assets	Daily a
System image or bare-metal backup	Recovery hosts, VMs, physical servers, NAS, and backup appliances	Weekly
Long-term protected-health-information archive	Clinical records and backup snapshots containing PHI	Month

All primary backup processes must run through scheduled jobs without routine human intervention. A manual backup may supplement, but never replace, the scheduled job. Failed jobs, missed schedules, insufficient storage capacity, upload failures, transaction-log lag above 15 minutes, and backup-window overruns must generate real-time alerts to IT Operations and create or update an incident ticket.

1.6 6. Encryption, Access, Residency, And Monitoring

- Backup files, disk arrays, NAS volumes, tape media, and cloud storage buckets containing Vitora data must use AES-256 encryption at rest before transmission and while stored. Production PostgreSQL archive files use GPG AES-256 encryption before upload; managed storage encryption must use AES-256 or an equivalent approved control.
- Backup-repository access is limited to named backup administrators using role-based access control, multi-factor authentication, least privilege, and separate administrator accounts. Shared credentials are prohibited.

- The backup platform must record immutable audit events for authentication, read, create, restore, retention-policy, deletion, and privileged-access actions. Security Operations reviews privileged backup access at least monthly.
- Offsite backup locations must comply with Kenya data-residency and data-sovereignty obligations. The storage country, replication country, provider legal entity, and subcontractor arrangements must be recorded and approved before production data is stored there. Azure South Africa is not an approved Kenya-resident hub-backup location while the facility requires Kenyan residency.
- Encryption keys must be stored separately from backup data in an approved secret-management system. Key custody, recovery access, rotation, and emergency access are controlled and logged.

\newpage

1.7 7. Retention, Archive, And Secure Disposal

Patient medical records and backup snapshots containing protected health information must be retained for a minimum of 20 years, or longer where applicable law, clinical need, litigation hold, payer rule, or contractual obligation requires it. The following matrix defines the minimum backup lifecycle; a legal, clinical, security, or investigation hold overrides automatic expiry.

Data type	Operational backup retention
Clinical records and PHI snapshots	90 days online or warm recovery storage
Financial, billing, payment, claims, and procurement records	90 days online or warm recovery storage
Audit and security logs	90 days searchable or warm recovery storage
System-state images, network configuration, and deployment artefacts	90 days online or warm recovery storage
Facility-hub encrypted bundles	14 local bundles and 90 days offsite recovery storage

Lifecycle policies must automatically move eligible older copies to cost-effective cold storage, retain immutable objects for their required period, and securely purge expired copies after a documented hold check. The 30-day operational dump retention previously used by `backup-db.sh` is not by itself sufficient for the mandatory 20-year PHI archive; Operations must configure and evidence the long-term archive before using the policy as production compliance evidence.

For end-of-life physical backup media, the responsible asset owner must use a recognized sanitization method appropriate to the media type, such as cryptographic erase and verified overwrite for reusable drives, degaussing where applicable, or physical destruction/shredding. A dated certificate of destruction is mandatory for any drive, tape, disk, or solid-state media containing sensitive health or operational data and must record the asset identifier, method, provider/witness, date, and authorizing officer.

1.8 8. Current Production Backup Control

Requirement	Current implementation or evidence	Required assu
Full snapshot	Daily GitHub Actions production database backup at 02:00 UTC / 05:00 EAT	Must meet Ti
Current baseline RPO	24 hours from daily snapshot cadence	Must improve
Current baseline RTO	24 hours	Must remain v
Backup content	PostgreSQL dump and SHA-256 checksum	`backend/scri`
Current storage	Private Azure Blob `db-backups` container with public access disabled	Add separate
Current operational retention	30 days in backup script configuration	Add protected
Restore validation	Monthly isolated drill	Expand to sch

1.9 9. Automated Backup Operating Procedure

1. The scheduled workflow authenticates to Azure using OIDC or another approved workload identity; no human performs the routine backup.
2. It checks available storage capacity, backup-window availability, and the prior job outcome before creating a backup.

3. It obtains short-lived, least-privilege access to the primary and isolated offsite destinations.
4. It invokes `backend/scripts/backup-db.sh` inside the application container for the full PostgreSQL snapshot; platform jobs create the required differential/incremental and transaction-log captures.
5. The job compresses the dump, performs a size sanity check, creates a SHA-256 checksum, encrypts the backup with AES-256 before upload, and uploads the backup and checksum to the protected repository.
6. The job copies the validated backup to the isolated immutable offsite location, records object-lock/retention status, and writes the backup metadata to the backup-control register.
7. The monitoring service verifies the expected object, checksum, age, transaction-log lag, capacity, and backup-window duration.
8. Any failure, warning, missed schedule, capacity threshold, transaction-log lag above 15 minutes, or backup-window overrun is dispatched immediately to IT Operations and creates an incident/ticket.

\newpage

1.10 10. Restoration Standard Operating Procedures

1.10.1 10.1 Common Recovery Controls

1. The Incident Commander or alternate Incident Commander declares the recovery event and records the selected recovery objective and target recovery point.
2. Operations Lead isolates affected systems, preserves relevant logs and the failed state, and opens the controlled recovery record.
3. Retrieve the selected backup and matching checksum into an isolated recovery environment using authorized recovery credentials.
4. Decrypt the backup using authorized key-custody procedures, verify the SHA-256 checksum, and record the result before any production replacement.
5. Application Lead validates migrations, representative data integrity, tenant isolation, authentication, audit logging, and required clinical workflows.
6. Incident Commander authorizes production cutover only after validation; Operations Lead records achieved RPO/RTO and Communications Lead notifies affected parties.

1.10.2 10.2 Single-File Or Object Recovery

1. Identify the object owner, classification, source backup, version, and requested destination.
2. Restore only to an isolated location or a new object version; never overwrite the production object before validation.
3. Verify file checksum, malware-scan result where applicable, access control, and content ownership.
4. Obtain the data owner or Incident Commander approval before replacing or exposing the recovered object.

1.10.3 10.3 Full Database Point-In-Time Recovery

1. Identify the last known-good time and ensure transaction logs from the full snapshot through that time are available.
2. Restore the selected full snapshot into isolated PostgreSQL, apply differential/incremental captures and transaction logs to the approved target time, and stop before the destructive or corrupting event.
3. Run schema, migration, row-count, tenant-isolation, audit-log, and representative clinical-workflow validation.
4. Obtain Incident Commander, Application Lead, and Security Lead approval before production cutover; reconcile any downtime records after restoration.

1.10.4 10.4 Bare-Metal, System-Image, Or Complete Environment Recovery

1. Build a clean host, VM, or cloud environment from approved infrastructure-as-code and a verified system image; do not restore an image suspected of compromise.
2. Restore protected configuration, network rules, certificates, secrets, application artefacts, and databases in dependency order.
3. Reapply least-privilege access, MFA, monitoring, alerting, backup schedules, immutability controls, and offsite replication before enabling user traffic.
4. Perform full acceptance checks and document actual RTO/RPO before the Incident Commander declares recovery complete.

\newpage

1.11 11. Testing, Reports, And Personnel Authorization

Test	Frequency	Minimum evidence
Sample backup restore and checksum verification	Monthly	Backup ID, checksum re
Point-in-time database restore	Quarterly after transaction-log capture is enabled	Selected target time, log
Full service and system-image failover	Semi-annually	Failover scenario, affecte
Facility-hub restore	Quarterly per supported hub deployment	Encrypted-bundle verifi

Each test requires a formal dated execution report signed or electronically approved by the tester, Operations Lead, Security Lead, and designated facility representative. The report must record the scenario, systems tested, backup identifiers, expected versus achieved objectives, failures, residual risks, corrective actions, owners, due dates, and closure evidence.

Authorized role	Primary responsibility	Alternate
Incident Commander	Declares a disaster, approves recovery-point selection and production cutover	Designated Operations
Operations Lead	Initiates technical backup and restoration workflows	Senior platform engine
Security Lead	Authorizes recovery after cyber incident and approves credential/key rotation	Designated security off
Facility representative	Activates clinical downtime arrangements and approves clinical resumption	Designated facility clin

Named primary and alternate personnel, after-hours contacts, and delegation dates must be maintained in the controlled operations contact register and tested during each full failover exercise.

1.12 12. Facility Hub Backup Policy

Facility hubs use encrypted Fernet backup bundles containing the SQLite database, synchronization state, and SHA-256 manifest. Hub operators must configure `HUB_BACKUP_ENCRYPTION_KEY`, retain the key separately from the device, and configure only approved offsite destinations. Refer to `docs/hub-backup-recovery.md` for operational commands and residency constraints.

Fernet provides authenticated encryption but does not by itself demonstrate the AES-256-at-rest requirement in section 6. Before a facility hub is approved as a production backup repository, the Security Lead must approve and evidence an AES-256-at-rest encryption control for the bundle or its storage layer, plus immutable offsite retention, access controls, and Kenya-residency compliance.

1.13 13. Compliance, Exceptions, And Review

Unauthorized modification, deletion, disabling, encryption, or destruction of backup data; bypassing backup controls; or failure to maintain required backup procedures is a security and compliance incident. It may result in access suspension, disciplinary action under employment or supplier terms, contractual remedies, reporting to regulators or law enforcement where required, and any other legal consequence available under applicable law.

Any inability to meet the backup schedule, 3-2-1 rule, encryption, immutability, residency, retention, 24-hour RPO, 24-hour RTO, or MTPD target must be recorded as an operational risk with compensating controls, owner, expiry date, and approval from the Security Lead, DPO, and designated facility representative. This policy is reviewed annually and after a restore failure, security incident, material infrastructure change, supplier change, or legal/regulatory change.

\newpage

1.14 14. Version And Approval Record

Item	Record
Current version	2.0
Last reviewed	15 October 2026
Next scheduled review	15 October 2027

Approval role	Name	Signature or approved electronic equivalent	Date
Operations Lead			
Security Lead			
Data Protection Officer / Compliance Lead			
Designated facility representative			